

IT Security Basics

Malware and Social Engineering

Malware

FH University of Applied Sciences TECHNIKUM WIEN

Definition Malware

- Unwanted programs
- Loaded onto the computer unnoticed
- Possible actions taken by malware
  - Reproduction
  - Taking over systems
  - Data theft
  - Unwanted manipulation
  - Spying on user activities
- Usually works unnoticed from users
- Only goal: causing damage

Malware by numbers



of CISOs say UK organisations are at the highest risk of material cyberattacks



of all malware attacks come from the web



of SMBs reported one or more ransomware attacks in 2023



of mobile-based malware attacks are trojans

5.5 billion

number of malware attacks globally in 2022

£21 billion

annual cost of cybercrime to UK businesses

450,000

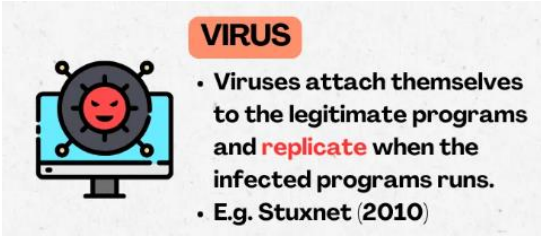
new types of malware and PUA registered daily

488 incidents

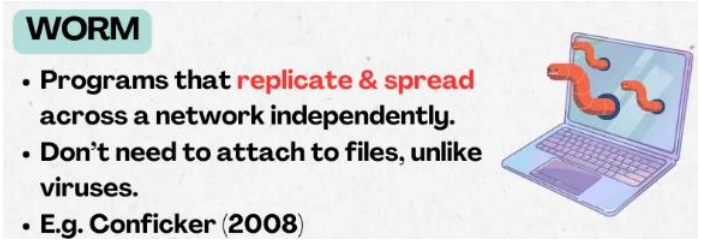
cybercriminals target the public administration sector more than any other

Source: https://cybersmart.co.uk/2024/02/demystifying-malware-the-5-stages-of-a-malware-attack/

Types of malware



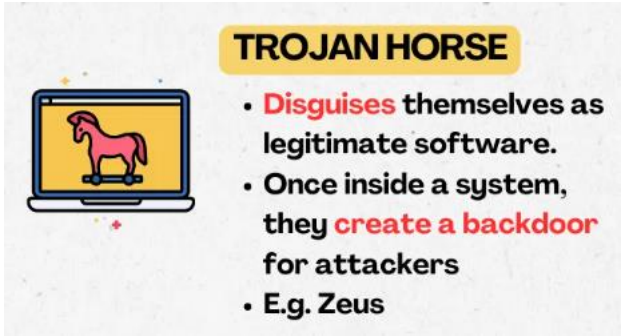
- Virus
  - Does not spread itself actively
  - Needs attachments or executable files to spread itself – some kind of host file
  - Historical seen: The first type of virus
  - Typical behavior: Destruction of files, performance problems
- Worm
  - Has active spreading and camouflage techniques
    - Does not need a host file to spread itself
  - Is not bind to any kind of file type
  - Modify data and programs
  - Typical behavior: Mass distribution, high network load



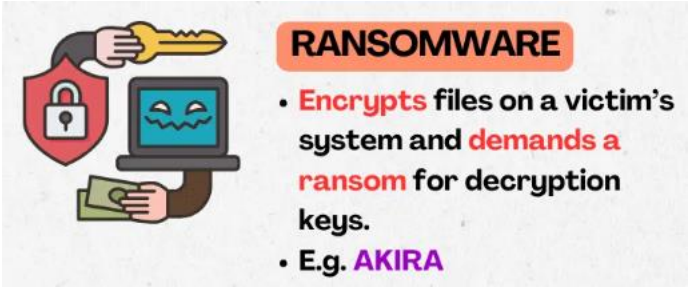
Source: https://www.pmfias.com/akira-ransomware-malware/

Types of malware

- Trojan horse
  - Fake useful functions
  - Malicious functions are running in the background
  - Sending user data
  - Unnoticed installation of spyware, remote access software and dialers (paid software for dialing into the Internet)
  - Typical behavior: Data theft, taking control of the system



- Ransomware
  - Encrypts all stored data
  - Local data and all data accessible in the network
  - Ransom in Bitcoins enables decryption
  - Typical behavior: Loss of data, high costs



Source: https://www.pmfias.com/akira-ransomware-malware/

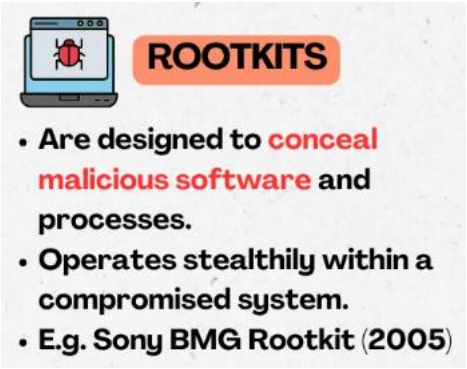
Types of malware

- Hoaxes
  - Mass distribution of pointless mails
  - Content is intended to unsettle readers and tempt them to act rashly and/or to forward the mails
  - Typical behavior: Fake news, damage reputation of others (people or companies)
- Scareware
  - Fake a serious problem
  - Offer to buy or download software to solve this fake problem
  - The download itself is usually a Trojan
  - Typical behavior: Causing panic, causing costs



Source: https://www.avg.com/de/signal/what-is-scareware

Types of malware



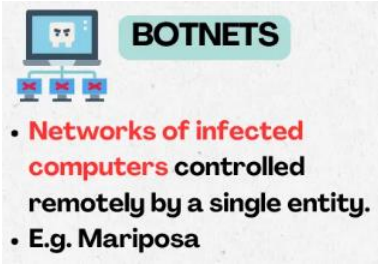
- Rootkits
  - Malicious code deeply embedded in the operating system or BIOS
  - Kernel itself or libraries affected
  - So deeply embedded, extremely hard to detect
  - Typical behavior: Allow unwanted and undetected access to the victims computer
- Adware
  - Software secretly installed on the computer
    - Often hidden in Open Source software
  - Unwanted advertisement pop-ups
    - Clicking on the ads costs money or downloads other types of malware
  - Typical behavior: Tracking online behavior of victims, causes costs, installs other malware



Source: https://www.pmfias.com/akira-ransomware-malware/

Types of malware

- Botnets
  - Bots = programs installed on victims computer
  - Bots work in background and attacker can use them to perform unwanted tasks on the victims computer
  - Used to send spams, phishing mails or perform DDoS attacks
  - Typical behavior: Create zombie-PCs to control in a botnet



- Cryptojacker
  - Uses the computing power of the victims computer to mine cryptocurrency
  - Attacker has no costs for the computing power
  - Based on malicious software or in websites embedded JavaScript code
  - Typical behavior: Reduces performance, cause costs



Source: https://www.pmfias.com/akira-ransomware-malware/
https://www.avast.com/de-de/c-protect-yourself-from-cryptojacking

Types of malware

- Besides that there also exists some subtypes of these types
- Examples:
  - Keylogger – logs the typed in keys, subtype of spyware
  - Bootkits – extension of Rootkit, infects the boot process
  - Logic bomb – malware that does not attack immediately, waits for specific conditions
  - Wipers – all malware with the primary goal to destroy data
  - Mobile malware – malware that is specific for mobile devices (worm, trojan, virus,…)
  - Hybrid malware – combination of different malware types
  - Fileless malware - malware that has no file, malicious code is directly in the memory
  - Etc.





Source: https://www.pmfias.com/akira-ransomware-malware/
https://sosafe-awareness.com/glossary/malware/

5 Stages of a web malware attack

- Entry
  - Accessing a compromise website
    - Trusted but hijacked website
    - Clicking on a wrong link
  - Malware can be downloaded by user or in background
- Distribution
  - Malware redirects the system to a exploit kit hosting website
  - Way of redirection depends on operation system and browser of the victim
- Exploitation
  - Exploit kit from the hosting website is downloaded and installed
  - The kit probes the system to find vulnerabilities that can be used
    - Everything is checked: Installed software, hardware, operation system, patches, etc.

5 Stages of a web malware attack

- Infection
  - Actual malware (=payload) is downloaded
  - Can be every kind of malware (virus, worm, trojan, ransomware, etc.)
- Execution
  - Malware is executed and starts it´s work
  - What is does depends on the type of malware and the goals of the attacker

How do malware attacks work?



1: Entry

The victim unknowingly visits a compromised website.



2: Distribution

The victim is redirected to an exploit kit hosting website, typically using a corrupted traffic distribution system (TDS).



3: Exploitation

The hosting site installs an exploit kit onto the victim's system, which loads it with malicious files in search of vulnerabilities.



4: Infection

The malware exploits these vulnerabilities to deliver its malicious payload.



5: Execution

The malware gets to work. For example, stealing or encrypting sensitive data.

Source: https://cybersmart.co.uk/2024/02/demystifying-malware-the-5-stages-of-a-malware-attack/

Social Engineering

FH University of Applied Sciences TECHNIKUM WIEN

Social Engineering

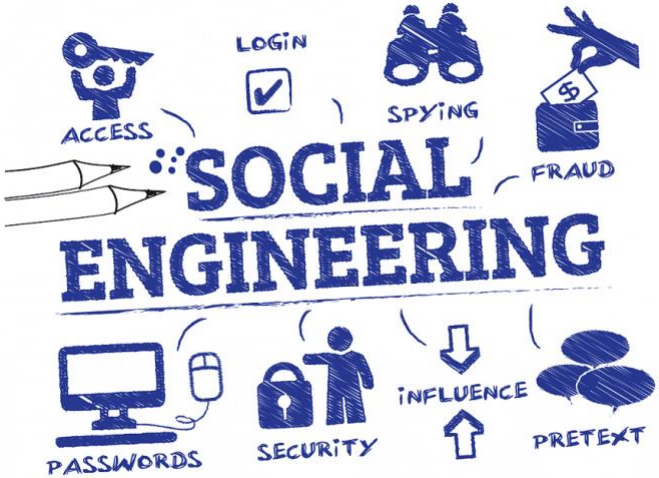


Social Engineering



Social Engineering

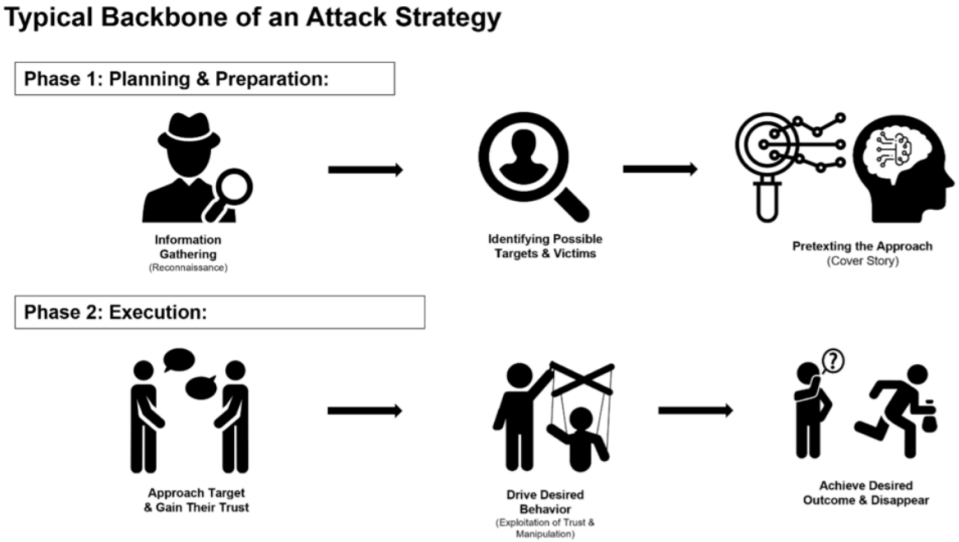
- Method that uses typical human behavior to gain access to secret information
- Exploiting the behaviors of trust to other people, helpfulness, fear or respect for authority
- Uses human weaknesses like stress or lack of knowledge to exerting pressure on people
- Good method to gain initial information → base of many other attacks



Source: https://www.techuseful.com/wp-content/uploads/2019/12/Social-Engineering-Attacks-765x537.png

Psychology behind social engineering

- Skills needed for social engineering
  - Being charming
  - Read people using e.g. body language or different sounds in the voice of people
  - Adapt the own behavior to the reaction of the victims



Source: https://www.informatik-aktuell.de/betrieb/sicherheit/social-engineering-angriffe-und-die-psychologie-dahinter.html

Psychology behind social engineering

- How to gain trust and/or trick people
  - Using authorities
    - Humans tend to immediately trust authoritarian persons
    - Therefore people trust managers (or other staff from leadership), lawyers, police officers or IT technicians
    - Pretending to be a person that is an authoritarian persons for the victim to gain the trust
    - Example: Acting as an CEO that wants you to transfer money to an angry supplier
  - Social proof
    - Using the principle “when others do it / trust it, then I can do that too”
    - Namedropping: Mentioning other (famous) people – in best case some the victim knows – that also trusts the system / person
    - Acting like someone the victim normally trust – e.g. from a partner company but the colleague the victim normally talks to is ill
    - Basically: Giving the victim the feeling he/she can trust because others or even the victim itself already trusted
    - Example: Ad with “10 000 people already registered” or fake interviews with Austrian stars like Armin Assinger

Psychology behind social engineering

- How to gain trust and/or trick people
  - Reliability
    - Consistent behavior is associated with reliable, intelligent and trustworthy – good properties
    - Using this by starting with easy meaningless requests that can be answered easily and without problems
    - As soon as the victim is used to answer, start asking more sensible requests
    - Victims feel inner pressure to continue answering even when getting suspicious
    - The longer the communication goes the harder it will be to say no
  - Time pressure: Once in a lifetime opportunity
    - Things that are limited in time or quantity are often perceived as more valuable and attractive
    - Leads to impulsive decisions without thinking to much about the consequences
    - Example: Receiving one of the only 15 available iPads when completing a survey

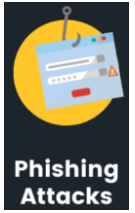
Psychology behind social engineering

- How to gain trust and/or trick people
  - Sympathy / Popularity
    - People automatically trust people who are attractive to them more
    - People automatically seems trustworthy when they are similar to us or sympatric for us
    - Similarity can be from the appearance but also from hobbies or interests
    - Humans automatically open up easier to people they like → more likely answer questions about secret information
  - Helpfulness
    - Closely connected with sympathy
    - Humans tend to help others when they are in trouble especially when the person is sympathetic to them
    - Example: Acting as a colleague that forgot his password or access card

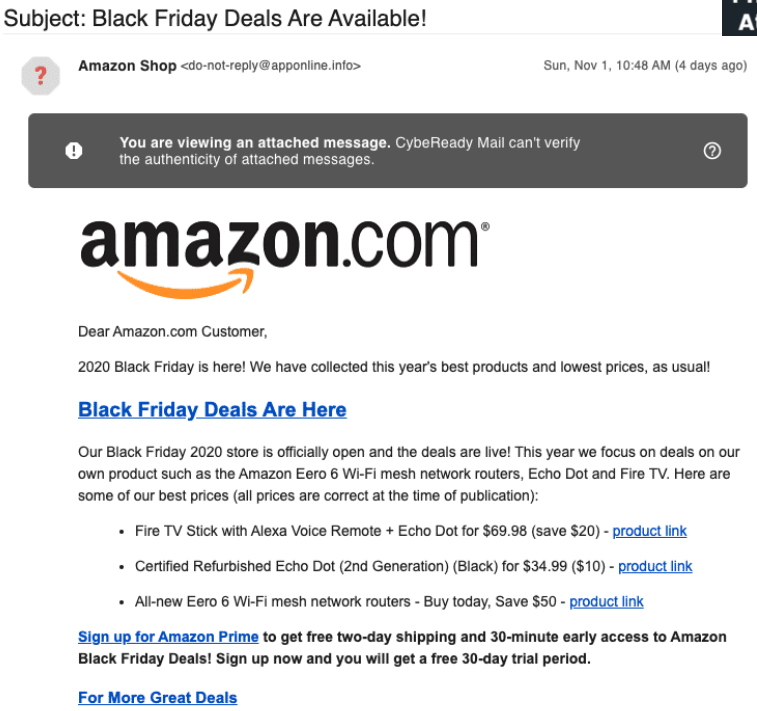
Psychology behind social engineering

- How to gain trust and/or trick people
  - Threats and anxiety
    - Often combines with time pressure
    - Anxiety influences the ability to think rationally and logically
    - Creating time pressure and threating when consequences after the time is over causes decisions without thinking
    - Examples: An angry boss wants you to transfer money to a partner company within the next hour or they will terminate contract
  - Curiosity
    - People are curious by nature and respond to exciting or exclusive content
    - Example: “Are you this on the photos on the website?”

Types of Social Engineering



- Phishing
  - Using fake websites or emails that look authentically and trustworthy
    - Looks like they are from legitimate organizations or people
  - Normally send as mass mails with no specific receiver
    - Reach as much people as possible
    - The more people, the more likely it is that someone falls for the trick
  - Goal: Getting secret information like passwords or credit card information



Subject: Black Friday Deals Are Available!

Amazon Shop <do-not-reply@apponline.info> Sun, Nov 1, 10:48 AM (4 days ago)

You are viewing an attached message. CybeReady Mail can't verify the authenticity of attached messages.

amazon.com

Dear Amazon.com Customer,

2020 Black Friday is here! We have collected this year's best products and lowest prices, as usual!

Black Friday Deals Are Here

Our Black Friday 2020 store is officially open and the deals are live! This year we focus on deals on our own product such as the Amazon Eero 6 Wi-Fi mesh network routers, Echo Dot and Fire TV. Here are some of our best prices (all prices are correct at the time of publication):

- Fire TV Stick with Alexa Voice Remote + Echo Dot for $69.98 (save $20) - product link
- Certified Refurbished Echo Dot (2nd Generation) (Black) for $34.99 ($10) - product link
- All-new Eero 6 Wi-Fi mesh network routers - Buy today, Save $50 - product link

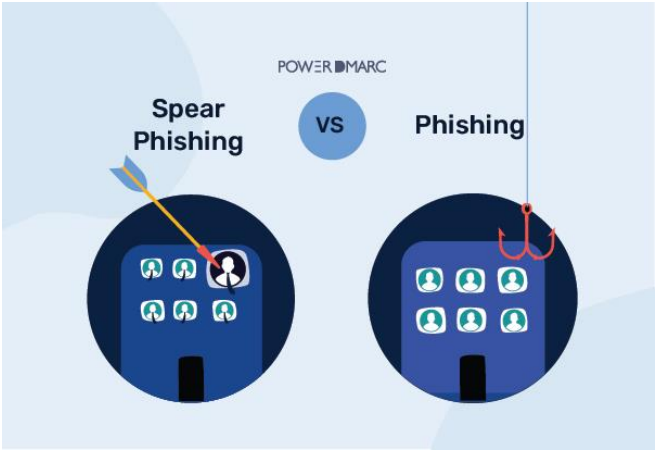
Sign up for Amazon Prime to get free two-day shipping and 30-minute early access to Amazon Black Friday Deals! Sign up now and you will get a free 30-day trial period.

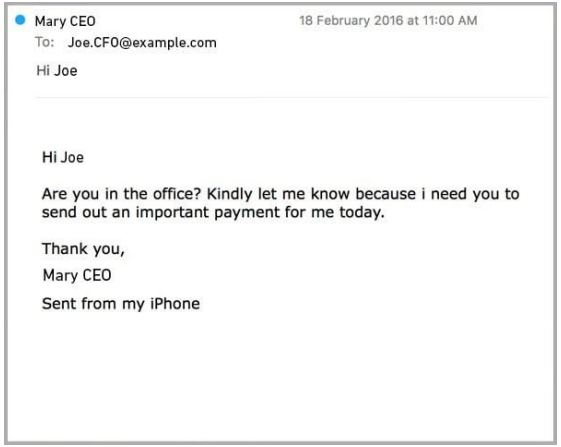
For More Great Deals

Source: https://assets-global.website-files.com/5d4ce6b87ec3662ff0c47b94/61d8bfaa0f33971a6f79c3d2_Social%20Engineering%20Micrographic.png
https://cybeready.com/wp-content/uploads/Screen-Shot-2020-11-05-at-13.09.28.png

Types of Social Engineering

- Spear-Phishing
  - Basically identical to phishing – using false messages and websites
  - Difference to normal phishing:
    - Designed to address one specific person or a small group of people (e.g. the finance department)
  - A lot more effort since specific information of the victim is needed to create that mail
  - Goal: Getting secret information like passwords or credit card information
  - Classical attacks: The “boss” needs something important




Mary CEO 18 February 2016 at 11:00 AM
To: Joe.CFO@example.com
Hi Joe

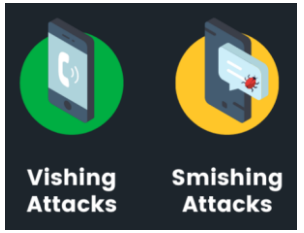
Hi Joe

Are you in the office? Kindly let me know because i need you to send out an important payment for me today.

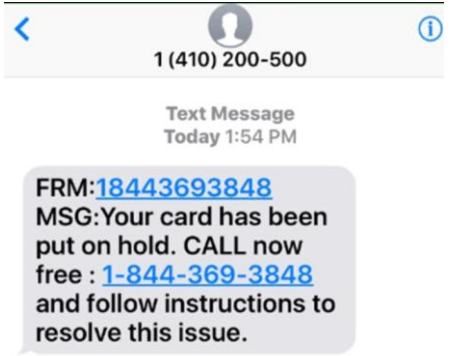
Thank you,
Mary CEO
Sent from my iPhone

Source: https://www.mailguard.com.au/hubfs/beware-of-spear-phishing-attacks.jpg
https://cdn-caklk.nitrocdn.com/sJCpruYkVvovUsWvtAEzkQwTuXjDDQLL/assets/images/optimized/rev-9df7324/powerdmarc.com/wp-content/uploads/2022/10/Spear-phishing-VS-Phishing2-01-01-602x321.jpg

Types of Social Engineering



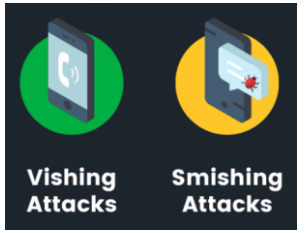
- Smishing
  - Short for SMS Phishing
  - Same as phishing but done over SMS or messenger services like WhatsApp, Signal or Telegram
  - Classical attacks: Son-daughter-trick, acting as a banking institution or a delivery service that cannot deliver a package due to missing information
    - Example: https://www.psni.police.uk/safety-and-support/keeping-safe/scams-and-fraud/whatsapp-family-impersonation-scam



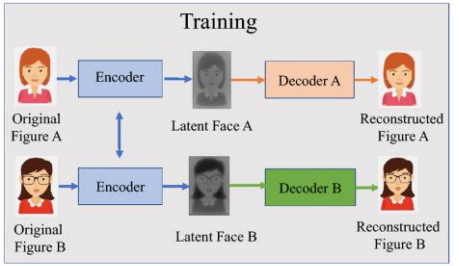
- Visching
  - Video Phishing
  - Phishing done over telephone calls
  - Normally acting as a customer, colleague, partner company or bank institute of the victim (company)

Source: https://clearvpn.com/blog-images/images/2023/01/example-smishing-attack.webp
https://assets-global.website-files.com/5d4ce6b87ec3662ff0c47b94/61d8bfaa0f33971a6f79c3d2_Social%20Engineering%20Micrographic.png

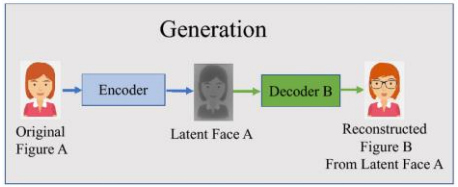
Types of Social Engineering



- Visching
  - Trick the victims using Deepfakes in form of Voice cloning or Video cloning
  - Voice cloning = technology that uses AI to imitate the voice of someone else
  - Face cloning = technology that uses AI to imitate the face and mimic of someone else
  - Requirements: Audio/video record of the victim
    - Depending on the tool and expected result a few seconds till minutes
  - Depending on the tool the results are extremely realistic
  - Further information:
    - https://www.researchgate.net/publication/349310566_A_Machine_Learning_Based_Approach_for_Deepfake_Detection_in_Social_Media_Through_Key_Video_Frame_Extraction
    - https://www.bsi.bund.de/EN/Themen/Unternehmen-und-Organisationen/Informationen-und-Empfehlungen/Kuenstliche-Intelligenz/Deepfakes/deepfakes_node.html



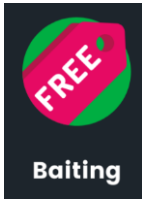
(a) Training Phase



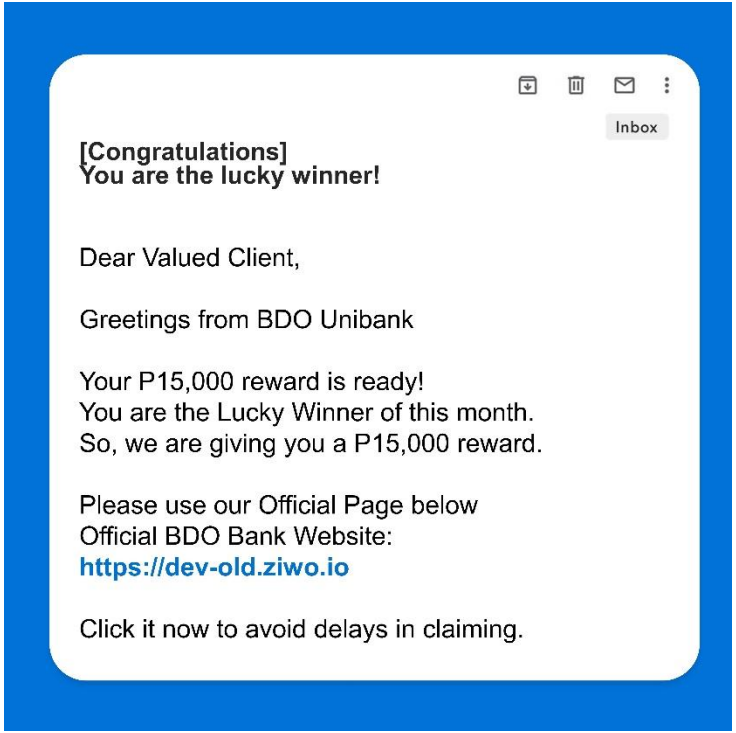
(b) Generation Phase

Source: https://www.researchgate.net/figure/Deepfake-video-creation-by-autoencoder_fig12_349310566
https://assets-global.website-files.com/5d4ce6b87ec3662ff0c47b94/61d8bfaa0f33971a6f79c3d2_Social%20Engineering%20Micrographic.png

Types of Social Engineering



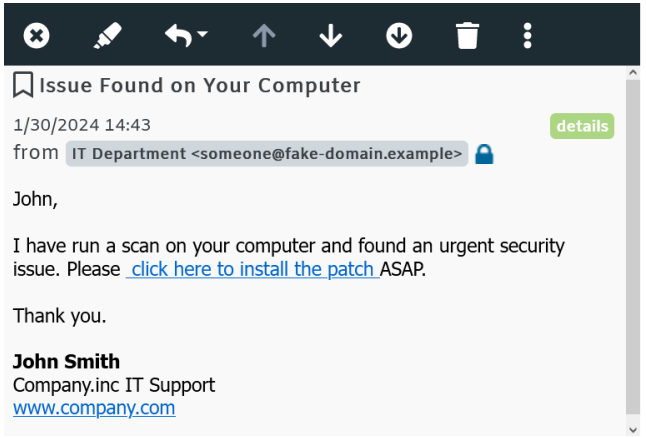
- Baiting
  - Stealing information by promising the victims false rewards
  - Trying to trick a victim to install malware by promising free software
  - Using a physical bait like e.g. an USB-stick
    - Curious people will take the stick and plug it in
    - On the stick is malware that will take action as soon as the stick is plugged in



Source: https://www.bdo.com.ph/content/dam/bdounibank/en-ph/cbg-digital-marketing/digital/bdo-antiscam/advisories/email-scam/Slide4.JPG
https://assets-global.website-files.com/5d4ce6b87ec3662ff0c47b94/61d8bfaa0f33971a6f79c3d2_Social%20Engineering%20Micrographic.png

Types of Social Engineering

- Pretexting
  - Creating a made-up scenario to trick victims
  - Goals:
    - Get information
    - Trick users to execute specific task like installing software or transferring money
  - These scenarios seems logical and realistic









Source: https://assets.cdn.seon.io/uploads/2021/10/8_type_of_soccialE-1024x721.png
https://sosafe-awareness.com/sosafe-files/uploads/2023/03/230321-glossary-page-social_engineering-06-1024x480.png
https://blog.mdaemon.com/hs-fs/hubfs/Pretexting-email-example.png?width=1910&height=1298&name=Pretexting-email-example.png

Types of Social Engineering



- Quid-pro-quo
  - Uses the classic principle of “give and take”
  - Helping the victim first by solving a problem or making a gift
  - Afterwards asking for a favor or information
  - Hard to say “no” since the victim already got help
  - Example: Giving free access to a online game and then asking for secret information
  - Also: Offering help but to be able to do that, some information is needed
  - Example: “I can fix the IT problem, but therefore I would need your credentials”



Source: https://cdn.corporatefinanceinstitute.com/assets/quid-pro-quo.jpg
https://assets.cdn.seon.io/uploads/2021/10/8_type_of_soccialE-1024x721.png

Types of Social Engineering

- Also possible offline without using any kind of technical devices:
- Classical method: dumpster diving
  - Search through the target's garbage
  - Find information about the victim's behavior and interests
  - Find possible confidential documents and information that had been disposed incorrectly



Source: https://cdn.ttgtmedia.com/rms/onlineimages/security-dumpster_diving-f_desktop.png

Types of Social Engineering

- Also possible offline without using any kind of technical devices:
- Classical method: tailgating
  - Attacker gain access to a closed area
  - Attacker “sneaks” directly behind an authorized person into office buildings, data centers, hospitals and other security-critical environments
  - Typical tricks
    - Acting like a colleague that forgot the key card
    - Acting like a delivery person carrying big and heavy packages
    - Acting like a new employee that does not have a key card so far
    - Acting like a visitor that has an appointment with an colleague of the victim



Source: https://cdn.ttgtmedia.com/rms/onlineimages/security-dumpster_diving-f_desktop.png

Types of Social Engineering

- Also possible offline without using any kind of technical devices:
- Classical method: shoulder surfing
  - Using crowded places to get personal or secret information
  - Looking over someone's shoulder while he/she types in a password on the phone or a PIN at the ATM
  - Listening to phone calls of other persons in public environment



Source: https://akm-img-a-in.tosshub.com/lingo/styles/medium_crop_simple/public/images/assets/202307/surfing1.jpg